



Mandatory Assignment 1 (Arbeidskrav 1)

Emne 2 - Spring 2026

Submission deadline: 10.03.2026 10:00

Contact information:

- Nett med samling i Trondheim: Camilla (camilla.jacobsen@Gokstadakademiet.no)
- Nett med samling i Porsgrunn: Sameea (sam.kha146@gokstadakademiet.no)
- Nett med samling i Stavanger: Linarte (lin.and555@gokstadakademiet.no)
- Nett uten fysiske samling: Kevin (kevin.bergan@Gokstadakademiet.no)

Assignment Format: Individual

Language: Norwegian or English

Page limit: max 12 pages. This includes text, screenshots, or other figures and tables. The list of the used references can come in addition to this.

File format: .docx or PDF file.

Support materials: All support materials are allowed - including the course books, course slides and course practical tasks. If you want to use a standard or framework being used in the lecture (e.g. NIST CSF 2.0, ISO27001 or similar) feel free to use it and cite it as a book.

Important: When it comes to citation of our course book, reference the page(s). For the slides, refer to which lecture and which slide number (slide number equals page number which is shown in your PDF reader).

Grading scale: A - F, where A is the best grade, E is the lowest pass grade, and F is failed.

Weighting: 50% of the overall grade.

Declaration of AI use

The Declaration on the Use of AI Tools and Resources form (last page of the assignment description) must be completed and placed before the assignment answers in the report.

This page is not counted as part of the 12-page limit. You will find the form at the end of this file (last page).

This assignment has three tasks.

Task A is mandatory. Then, you can choose practical task B **OR** answer task C. Task A is 70% of the grade, B and C equal both 30%. If you choose to complete all three tasks, I will only censor A and B. C is in this case not graded.

1. Case description

NordElektro AS – Digital Transformation 2026

You are working as a **junior information security consultant** for NordElektro AS in Norway. NordElektro is one of the largest electronics retailers in the Nordic region and operates many physical stores across Norway, Sweden, Denmark, and Finland, in addition to a well-established online shop. The company employs several thousand employees, working in retail stores, logistics and warehouses, customer support, administration, and IT operations. NordElektro's business model depends on the high availability of digital systems, especially during peak sales periods such as campaigns, weekends, and seasonal sales. NordElektro relies heavily on information systems to support its daily operations.

Physical stores depend on point-of-sale systems to process payments and access pricing and inventory information. Central systems handle inventory management, logistics, supplier coordination, and pricing updates across all stores. In addition, NordElektro processes and stores large amounts of customer data, including personal information, purchase history, warranty data, and service requests. Internal systems are also used for HR, finance, and internal communication. These systems are hosted on a combination of Linux and Windows servers and are connected through a wide network of infrastructure linking stores, warehouses, and central IT systems.

Over the past year, NordElektro has experienced several operational and security-related challenges. During periods of high activity, some central systems have become slow or unavailable, resulting in delays at checkout counters in physical stores and failed or delayed online orders. In some cases, stores were temporarily unable to sell products because systems were not responding. These incidents caused frustration among customers and store employees and led to direct financial losses. In several of these situations, incidents were detected late. IT operations staff often became aware of problems only after store employees or customers reported issues. Although system logs existed, they were not actively monitored, and there was no clear overview of which alerts should trigger immediate action.

As a result, incidents were handled reactively rather than proactively. Another challenge identified by management was unclear responsibility during incidents. When systems were unavailable, it was not always clear who had the authority to make decisions, who should communicate with store managers, or who was responsible for documenting the incident and

ensuring follow-up actions. This led to delays, inconsistent responses, and limited learning from previous incidents.

NordElektro also performs regular backups of critical systems. However, management has identified weaknesses in backup and recovery practices. Recovery procedures are poorly documented, backup restoration is rarely tested, and some employees are unsure how long it would take to restore critical systems in the event of a serious incident. This uncertainty creates a risk for business continuity, especially if a major outage or security incident were to occur. Due to these challenges, NordElektro's management in Norway is concerned that a larger security incident or prolonged system outage could significantly impact business operations, customer trust, and compliance with legal requirements.

To address these challenges, NordElektro Norway has decided to strengthen its information security posture using structured methods and best practices from the field of information security. This massive security modernization project is called "The Digital Shield." Following the implementation of the Digital Security Act (NIS2), the NordElektro Norway is transitioning from a traditional IT security model to a proactive, risk-based approach using the current version of the NIST Cybersecurity Framework (CSF). The project involves upgrading 400+ physical stores with new cloud-based Point-of-Sale (POS) systems, a centralized customer management platform, and a modernized webshop.

2. Tasks

Task A (70%) – This task is mandatory.

Task A.1

To comply with the NIS2 directive, NordElektro must adopt a comprehensive cybersecurity risk management strategy. Walk through each of the core functions of the most current version of the **NIST CSF** and explain how they should be specifically applied to NordElektro's new retail environment. Your response should address:

- How will NordElektro establish its cybersecurity "Security Culture"? Discuss the importance of defining roles (Accountability vs. Responsibility) and managing supply chain risks for their cloud-based payment providers.
- How will the company map its critical assets (customer data, POS hardware)? Discuss the role of risk assessment (e.g., probability x consequence) in prioritizing these assets.
- What technical safeguards are necessary to protect the "CIA Triad"? Focus on security awareness training for store clerks and the use of data security measures like encryption.
- How can NordElektro implement "Continuous Monitoring" to find unauthorized traffic or rogue devices in a busy megastore?
- Describe the steps NordElektro must take when a potential breach is detected to meet the NIS2 requirement for rapid incident reporting.
- How does the company ensure business continuity so that stores can keep selling products even after a major system failure?

Task A.2

NordElektro's digital transformation relies heavily on moving away from a traditional network perimeter toward a Zero Trust architecture. You are tasked with designing the access control logic for the new centralized management platform. Provide a detailed analysis and recommendation for NordElektro's IAM setup. What needs to be in place to introduce IAM based on this scenario? In your response, compare the RBAC (Role-Based Access Control) and ABAC (Attribute-Based Access Control) models. Explain why a "part-time warehouse worker" should have different access rights than a "Regional Store Manager," specifically focusing on the Principle of Least Privilege. Furthermore, discuss how "context" (such as the employee's location, the time of day, or the health of their device) should influence whether a

login is permitted. Finally, select 3 out of OWASPs Top 10 (see <https://owasp.org/Top10/2025/>) and explain how effective identity management serves as a primary defense and unauthorized privilege escalation based on the use case.

Task A.3

NordElektro Norway AS has set a strategic goal to achieve **ISO/IEC 27001:2022** certification to demonstrate its commitment to international security standards. As part of this transition, the company is moving away from ad-hoc security fixes toward a formal Information Security Management System (ISMS). A critical requirement of ISO 27001 (specifically Annex A.5.9 and A.8) is the systematic identification of assets and the assessment of risks based on the interaction between specific threats and vulnerabilities. You are tasked with leading the risk assessment for the new "Click & Collect" system, ensuring that the process follows a standardized, reproducible path that satisfies both ISO requirements and the **NIS2 Directive**.

Task A.3.1

The foundation of any ISMS is a clear understanding of what needs to be protected. According to ISO 27001, NordElektro must maintain an Information Asset Register (IAR). You must begin by identifying and classifying the assets involved in the Click & Collect process. Identify at least two examples for each of the following categories: Informational Assets (e.g., customer PII or transaction logs), Supporting Assets (e.g., cloud-hosted SQL databases or physical POS terminals), and Intangible Assets (e.g., brand reputation or customer trust). For each asset, you must assign an Asset Owner. Explain why assigning a specific owner—rather than the IT department as a whole—is vital for Accountability and how this supports the "Govern" function of NIST CSF 2.0.

Task A.3.2

A risk only exists when a Threat (a potential cause of an unwanted incident) can exploit a Vulnerability (a weakness in an asset or control). For this sub-task, focus on the "Customer SQL Database" asset. Identify one specific vulnerability (such as outdated software protocols or inadequate input validation—referencing NSM Top 10 #7) and one corresponding threat actor (such as an external cybercriminal or a disgruntled insider). Describe a detailed threat scenario where these two elements intersect to result in an incident. Evaluate this scenario against the CIA Triad, explaining exactly how it would impact the Confidentiality (data leak), Integrity (data manipulation), and Availability (system downtime) of NordElektro's services.

Task B (30%) – You can choose this task, or task C.

The security of NordElektro's data depends on the correct application of cryptography. You must define a data-at-rest and data-in-transit policy for the following three data types stored in the centralized database: User Passwords, Norwegian Personnummer and Transaction History.

1. Data at Rest: Explain the technical necessity of using one-way Hashing with a salt (e.g., Bcrypt or PBKDF2) for passwords versus reversible Symmetric Encryption (e.g., AES-256-GCM) for Personnummer. Discuss why hashing is the only acceptable method for password storage and how AES-GCM provides "Authenticated Encryption".
2. Data in Transit: NordElektro is aiming to use TLS 1.3 for all communication. Analyze two specific security advantages of TLS 1.3 over its predecessors, such as the reduction in supported cipher suites to modern algorithms like ChaCha20-Poly1305 or AES-GCM, and the elimination of vulnerable legacy handshakes.
3. Future-Proofing: Define the concept of Perfect Forward Secrecy (PFS). Explain how using ECDHE (Elliptic Curve Diffie Hellman Ephemeral) for key exchange ensures that even if NordElektro's long-term private server key is compromised in the future, past recorded communications remain encrypted and protected.

Task C (30%) - You can choose this task, or task B.

Task C.1

Based on your threat scenarios in **A.3.2**, they must be prioritized. Use the DREAD methodology to perform a quantitative assessment of the "SQL Injection resulting in a Data Breach" scenario. Assign a score of 1 to 5 for each category: Damage (the severity of the impact), Reproducibility (how easily the attack can be repeated), Exploitability (the technical difficulty), Affected Users (the scope of the impact), and Discoverability (how easily the flaw can be found). You must provide a clear, evidence-based justification for each score. Calculate the total value (out of 25) and map it onto a risk matrix to determine if the risk level is Low, Medium, or High.

DREAD Category	Score (1-5)	Justification (Detailed reasoning)
Damage		
Reproducibility		
Exploitability		
Affected Users		
Discoverability		
Total Score	/25	

Important: For all tasks, use information from the slides and course books. Refer to the slide/page where you have found information for your solution proposal in accordance with the formal requirements mentioned on the first page of the exam.

3. AI Declaration

Copy this into your submission and fill it out. Mark with bold letters what apply (Yes/No):

Declaration of the Use of AI Tools and Resources

The checklist below must be completed:

- **Text correction:** Have parts of the text been checked using tools such as Grammarly, Ginger, LanguageTool, or similar? Yes / No
- **Text generation:** Have parts of the text been generated using tools such as ChatGPT, Jasper, WriteSonic, or similar? Yes / No
- **Writing assistance:** Have any ideas or approaches in the report been suggested by tools such as ChatGPT, Google Bard, or similar? Yes / No
- **Image generation:** Have any images/figures in the report been generated using tools such as Midjourney, DALL·E, or similar? Yes / No
- **Other AI tools:** Have you used any other AI tools? If yes, please specify here:

Have you used any AI-based tools or resources in the preparation of this report?

If yes, specify the tool and its purpose below.

1. **Text generation** – If you used text-based tools, which tasks were completed with AI assistance, and how?
2. **Images and figures** – If you used image/figure generators, which images or diagrams were AI-generated?

I declare that all use of AI tools or resources has been clearly disclosed either in the report or in this declaration form.

Candidate number / Date